

הדוח הזה עונה על שתי שאלות: כמה ילדים המערכת מחזיקה בכל איזור, ומה עוד עומד בדרך. כל מספר כאן נמדד באותו יום מול המערכת החיה. מה שלא נמדד — כתוב שלא נמדד.

7

פערים לפני פרודקשן

מתוכם 3 חוסמים

36,000

אחרי מיגרציית האצווה

הקוד מוכן, ה-SQL מחכה להדבקה

10,300

ילדים משחקים בו-זמנית

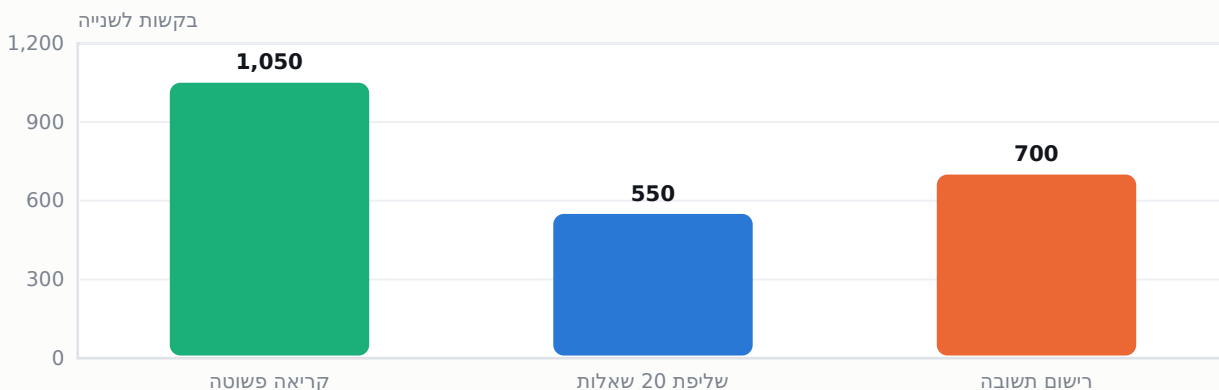
היום, כפי שהמערכת עובדת עכשיו

המסקנה בשורה אחת

צד המשחקים בשל: התקרה היא Supabase, והיא רחוקה. צד הטיטור לא נמדד מעולם תחת עומס אמיתי, ושלושה דברים חוסמים יציאה לאוויר — כולם תיקונים של דקות, אף אחד מהם לא דורש כתיבת קוד.

התקרה של מסד הנתונים, כפי שנמדדה

בכל אחת מהנקודות, ולכן אלה המספרים של השירות ולא של המחשב CPU המחולל היה מתחת ל-50%. wrk, 2 threads.



מעבר לנקודות האלה התפוקה מפסיקה לעלות וההשהיה מוכפלת — זו ההגדרה של שרת רווי. ההשהיה עצמה היא 100 מילישניות בין אם השרת בטל ובין אם הוא ב-600 בקשות לשנייה: זה זמן ההלוך-חזור לאזור, לא עבודה. אין יותר מה לכוון בשאילות.

שלושת החוסמים

מפתח LemonSqueezy

אי אפשר לאמת תשלום

deploy-לשני ה-backends

כל התיקונים מחכים בריפו

הדבקת שתי מיגרציות

בלעדיהן: מנוי חינם לכל דורש

אף אחד מהם אינו כתיבת קוד. כולם בעמוד 4.

מה כל איזור נוגע בו, ומה מגביל אותו

משחק לא נוגע בשרתים שלנו בכלל: הדפים יושבים ב-Cloudflare והמשחק מדבר ישירות מול Supabase. הטיטור הוא ההפך — כל בקשה עוברת דרך Render ומחכה למודל.

איזור	במה נוגע	מה מגביל	בו-זמנית	מקור
משחקים	Cloudflare + Supabase	Supabase	10,300	נמדד
משחקים, אחרי האצווה	Cloudflare + Supabase	Supabase	36,000	נגזר
דפים סטטיים	בלבד Cloudflare	אין מעשית	ללא הגבלה	—
צ'אט הטיטור	Render → OpenAI	המודל	לא נמדד	חסר
יצירת שיעור	Render → OpenAI/Gemini	תהליך הרקע	שביר	ראה להלן
הרשמה והתחברות	Supabase Auth	לא נמדד	לא נמדד	חסר

למה המשחקים מחזיקים כל כך הרבה

סשן של עשר שאלות עולה 14 קריאות היום. פרוס על ארבע דקות זה 0.06 קריאות לשנייה לילד, ו-600 קריאות לשנייה מתחלקות ל-10,300 ילדים.

עם תיבת היוצא — התשובות נאספות בדפדפן ונשלחות יחד — אותו סשן עולה 4 קריאות, וזה 36,000 ילדים על אותו מסד נתונים בדיוק. הקוד כבר עשה את זה; ה-SQL מחכה להדבקה.

אותו דבר, בתמונה

כמה משתמשים בו-זמנית בכל איזור. הטיטור ריק כי הוא לא נמדד, לא כי הוא אפס.



ומה לא ידוע על הטיטור

עד היום כל בקשה החזיקה thread של עובד לאורך כל קריאת המודל — שניות — ומאגר ה-threads היה 40. זו הייתה התקרה: כ-40 שיחות במקביל, וכל אחת מעבר לזה חיכתה בתור. היום 12 הפונקציות שמחכות למודל הן async, והבקשה משחררת את ה-thread בזמן שהמודל חושב. התקרה עברה למגבלת הקצב של ספק המודל — אבל היא לא נמדדה, כי כל מדידה כזו עולה כסף אמיתי. כדי למדוד: לקבוע תקרת הוצאה, להריץ ramp קצר מול חשבון בדיקה, ולקרוא את מגבלות הקצב בתשובה.

האודיט הראשון היה ב-9 בספטמבר. כל ממצא נבדק מחדש מול המערכת החיה, והפעם גם עם חשבון זמני — כדי לענות על מה שהאודיט הראשון לא יכול היה: מה משתמש מחובר זר מצליח להגיע אליו.

הממצא	מה היה	מצב
מנוי בתשלום מהדפדפן	חשבון חנימי הכניס plan=annual עד 2099 — התקבל	נסגר
בנק השאלות	106,096 שורות עם התשובות, קריאות לכל מבקר	נסגר
kid_unit_lesson_progress	בלי בכלל: קריאה וכתובה אנונימית	נסגר
מפתחות תשובות למבחנים	14 מפתחות, קריאים אנונימית	נסגר
תוכן שיעורים	150 שורות שנוצרו במודל, לכל אחד באינטרנט	נסגר
מכסת ההודעות	גם למשלמים, ומרוץ בין בקשות LIMIT=20	נסגר
פתוח Swagger	כל נתיב וכל סכמה, לכל אחד	בקוד
CORS m-localhost	בפרודקשן, עם credentials	בקוד
תוכן ילדים בלוגים	הטקסט המלא של הילד, פעמיים, ל-Render	נסגר
origin בלי postMessage	כל חלון יכול היה לזייף סיום משחק	נסגר
מעקב בדפי ילדים	בשני דפים של ילדים Google Analytics	נסגר
כותרות אבטחה	אין CSP, אין HSTS, אין X-Frame-Options	חלקי

"נסגר" = תוקן ונבדק. "בקוד" = התיקון בריפו, נכנס לתוקף ב-deploy הבא. "חלקי" = חי במראה, ממתין להגדרה ב-Cloudflare עבור iakids.app.

ומה שנמצא תקין

הבידוד בין משפחות מחזיק, וזה החלק שהכי חשוב. זר מחובר שביקש פרופילי ילדים, שיחות, סשנים, שימוש, פניות תמיכה ורשימת מנהלים — קיבל אפס שורות מכולן.
בנוסף: בדיקת בעלות על ילד בכל 17 נתיבי הטיטור, אימות token מול Supabase בכל בקשה, העלאות שיעורי בית מוגבלות לתיקייה של המשתמש ב-bucket לא ציבורי, חתימת HMAC על ה-webhook, צ'אט מרונדר דרך textContent, ואין eval או SQL גולמי בשום מקום.

שבעה פערים. שלושה חוסמים, וכולם — כולל החוסמים — הם פעולה של דקות, לא כתיבת קוד.

#	מה	למה זה משנה	איפה	דחיפות
1	הדבקת שתי מיגרציות	על חמש טבלאות, ומכסת ההודעות RLS	SQL editor	חוסם
2	deploy-לשני ה backends	מכסה — הכל מחכה, Swagger, CORS, async,	Render	חוסם
3	מפתח LemonSqueezy	ריק. אי אפשר לאמת webhook או לקרוא תשלום	backend/.env	חוסם
4	כותרות ב-Cloudflare	iakids.app מול CSP ו-HSTS	Transform Rules	גבוה
5	תור לעבודה הכבדה	אודיו ותמונות מתים ב-deploy	קוד	גבוה
6	אין ניטור שגיאות	שום דבר לא מדווח כשמשהו נשבר	קוד	בינוני
7	אין בדיקות למשחקים	100 משחקים, אפס בדיקות אוטומטיות	קוד	בינוני

שלושת החוסמים, בפירוט

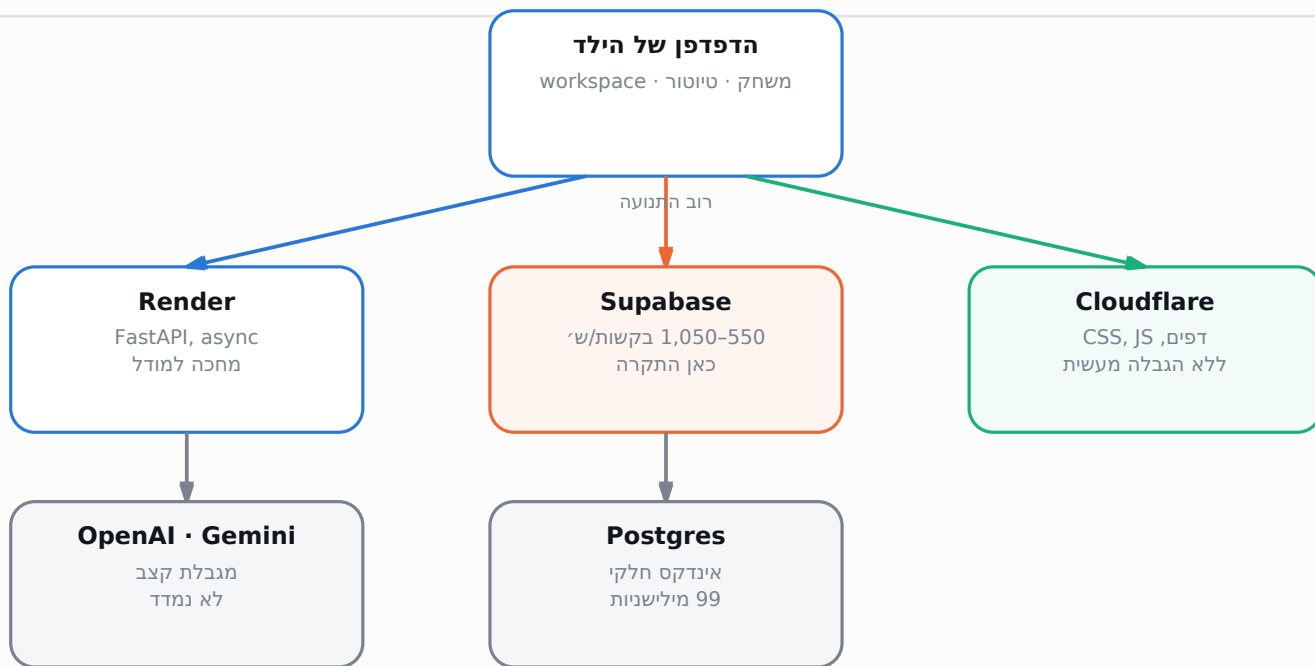
- עד שהמיגרציות לא מודבקות: כל בעל חשבון Google נותן לעצמו מנוי לכל החיים בקריאה אחת, מפתחות התשובות למבחנים גלויים, והמכסה חוסמת דווקא משלמים הקוד שסוגר את Swagger, מוציא את localhost מ-CORS, מפסיק להדפיס דברי ילדים ללוגים והופך את הטיטור ל-async — כולו בריפו, אף שורה ממנו לא באוויר
- שני מפתחות LemonSqueezy ריקים, ולשני המנויים אין lemon_order_id: אין דרך לאמת שתשלום קרה, ואין דרך לדעת מאיזו מדינה הלקוח

רשימת יציאה לאוויר

- ☒ Postgres 16 על חמש הטבלאות — נכתב ונבדק מול RLS
- ☒ מכסת הודעות אוטומית לפי תוכנית — נכתבה ונבדקה
- ☒ תיבת יוצא לתשובות, קריאה אחת במקום עשר
- ☒ זהות אחת לאתר ולמשחקים
- ☒ כותרות אבטחה ו-CSP — חיים במראה
- ☐ הדבקת chat_quota.sql_20260910 ו-rls_findings.sql_20260910
- ☐ הדבקת user_locations.sql_20260910 ו-game_bank_batch.sql_20260910
- ☐ deploy ל-iakids-backend ו-iakids-ai-tutor-he
- ☐ APP_ENV=prod בשני השירותים ב-Render
- ☐ LEMON_API_KEY ו-LEMON_WEBHOOK_SECRET
- ☐ Cloudflare ב-iakids.app מול CSP ו-HSTS
- ☐ בדיקה חוזרת: tools/security_check.py מחזיר אפס

מה שלא נמדד, ולכן לא נטען

כמה שיחות טיטור במקביל · כמה הרשמות בדקה · עומס אמיתי ממספר מכונות · האם הגיבויים של Supabase ניתנים לשחזור · כמה עולה חודש בעומס מלא.



מה זה אומר

רוב התנועה של האתר — כל מה שילד עושה במשחק — לא עוברת בשרת שלנו בכלל. היא נוגעת ב-Cloudflare, שאי אפשר להעמיס אותו, וב-Supabase, שנמדד ורחוק מלהיות מוצף. אלא במודל עצמו threads-נמצא במסלול של הטיטור בלבד, והוא כבר לא מוגבל ב Render.

הצעד הבא לתפוסה, לפי הסדר

- 1 להדביק את מיגרציית האצווה — פי שלושה וחצי ילדים, בלי לשלם על דבר
- 2 לשדרג את ה-compute ב-Supabase, ולמדוד שוב את שלושת המספרים מעמוד 1
- 3 להעמיס ממספר מכונות — התקרה הנוכחית נמצאה ממכונה אחת, ולכן היא רצפה
- 4 רק אחרי שהקריאות יהיו באמת החצי הגדול, read replicas,

מקורות: tools/CAPACITY.md · tools/PERFORMANCE.md · SECURITY.md · TODO.md